

NETWORK FORENSICS

Protocol Inspection — Complete Reference

Protocols: DHCP | ARP | ICMP | TCP | UDP | DNS | HTTP | SSL/TLS | HTTPS

1. Executive Summary

This document provides a comprehensive technical analysis of 10 network protocols, examining their packet structures, normal behavioural characteristics, and suspicious indicators that may signal active attacks or malicious reconnaissance. Each protocol section deconstructs packet fields, establishes a baseline of normal behaviour, and maps attack techniques to observable traffic patterns — giving SOC analysts, blue teams, and network engineers a precise reference for threat detection.

Coverage at a Glance

Protocol	Port / Layer	Normal Signature	Key Attacks	Primary IOC
DHCP	UDP 67/68	DORA sequence, unique Txn ID	Starvation, Rogue DHCP	Unknown DHCP servers, exhausted pool
ARP	Layer 2	Request → Reply, FF:FF broadcast	Sweep, Spoofing, MITM	Gratuitous replies, duplicate MACs
ICMP	IP layer	Type 8 req / Type 0 reply pair	Exfiltration, Flood, Recon	Oversized data, external unsolicited replies
TCP	Transport	SYN→SYN/ACK→ACK handshake	SYN flood, RST attack, Hijack	Half-open floods, port 4444, retransmission
UDP	Transport	Connectionless, VoIP/gaming	Port scan, Flood, C&C beacon	ICMP unreachable spikes, dead DNS queries
DNS	UDP 53	Matching Txn IDs, query→reply	Zone Transfer, Tunneling, DGA	TCP port 53, oversized queries, random domains
HTTP	TCP 80/8080	FQDN, plaintext, status codes	SQLi, XSS, LFI, Brute Force	Tool names in user-agent, unusual extensions
SSL/TLS	TCP 443	Full handshake, valid cert chain	Handshake bypass, fake cert	Missing handshake, self-signed certs, MITM
HTTPS	TCP 443/8443	Encrypted, cert hostname match	C&C, Ransomware staging	Spurious retransmission, ZeroWindow, cert mismatch

2. Protocol Deep-Dive Analysis

2.1. DHCP — Dynamic Host Configuration Protocol

Packet Structure

Field	Size / Type	Description
OPCODE	1 byte	1 = Request (client→server), 2 = Reply (server→client)
Hardware Type	1 byte	Type of hardware address — e.g. Ethernet (1), IEEE 802 (6), ATM
Hardware Length	1 byte	Length of the hardware (MAC) address in bytes
Hops	1 byte	Number of relay agents traversed; used to find DHCP server across subnets
Transaction ID	4 bytes	Random number unique to a request/response exchange
Seconds Elapsed	2 bytes	Seconds since client first requested an IP; useful for detecting retries
Flags	2 bytes	Bit 0: Broadcast flag — client signals whether it can accept unicast or broadcast
Client IP (ciaddr)	4 bytes	Client's current IP (populated in Request/Renew, else 0.0.0.0)
Victim IP (yiaddr)	4 bytes	IP address offered by the DHCP server to the client
Server IP (siaddr)	4 bytes	IP address of the DHCP server
Gateway IP (giaddr)	4 bytes	Relay agent IP; used when DHCP server is on a different subnet
Client HW Address	16 bytes	Client MAC address — used by server to track and assign leases
Server Hostname	64 bytes	Optional — server's hostname string
Boot File	128 bytes	Optional — path to a boot image (used in PXE boot environments)
Options	Variable	Code 53 = DHCP message type, Code 50 = requested IP, Code 255 = end

Normal Behaviour

- References BOOTP — a client/server protocol that DHCP extends
- DORA sequence must follow this exact order: Discover → Offer → Request → Acknowledge
- Transaction ID is unique per request-response pair — same ID links a Discover to its Offer
- Discover message: source IP = 0.0.0.0, destination = 255.255.255.255 (broadcast, no IP yet assigned)
- Offer & ACK messages: source = DHCP server IP, destination = 255.255.255.255 (broadcast delivery)
- Request message: source = 0.0.0.0, client IP = newly offered IP, destination = 255.255.255.255
- Transport: UDP port 67 (server listens), UDP port 68 (client listens)

Suspicious Indicators & Attack Patterns

DHCP Starvation [CRITICAL]

Attacker floods the DHCP server with Discover requests using spoofed MAC addresses. The server assigns an IP lease for each unique MAC, rapidly exhausting the entire address pool. Legitimate devices then fail to obtain IPs. This is commonly followed by a Rogue DHCP Server attack — the attacker stands up their own DHCP server while the legitimate one is unavailable, handing out IPs that point to attacker-controlled gateways. Every subsequent connection from victims routes through the attacker.

Rogue DHCP Server / DHCP Spoofing [CRITICAL]

After starvation or independently, an attacker introduces an unauthorised DHCP server on the network. It responds to client Discover messages faster than the legitimate server, issuing leases with a malicious default gateway or DNS server. Victims route all traffic through the attacker. Detection: watch for DHCP Offer messages originating from unknown IP/MAC sources not matching the authorised server.

- Watch for: massive volumes of DHCP Discover packets with varied source MACs in rapid succession
- Watch for: DHCP Offer responses from unexpected IP addresses — indicates rogue DHCP server
- Watch for: IP address pool exhaustion events in DHCP server logs alongside packet captures
- Watch for: clients receiving default gateways pointing to internal unknown hosts

2.2. ARP — Address Resolution Protocol

Packet Structure

Field	Size	Description
Hardware Type	2 bytes	Hardware address type — 1 = Ethernet, 6 = IEEE 802
Protocol Type	2 bytes	Protocol address type — 0x0800 = IPv4, 0x86DD = IPv6
Hardware Length	1 byte	Length of hardware address (6 for MAC addresses)
Protocol Length	1 byte	Length of protocol address (4 for IPv4)
Operation Code	2 bytes	1 = ARP Request, 2 = ARP Reply
Source Hardware Address	6 bytes	Sender's MAC address
Source Protocol Address	4 bytes	Sender's IP address
Target Hardware Address	6 bytes	Receiver's MAC (FF:FF:FF:FF:FF:FF in requests — broadcast)
Target Protocol Address	4 bytes	Receiver's IP address being queried

Normal Behaviour

- ARP Request is always broadcast to FF:FF:FF:FF:FF:FF — every host on the segment receives it
- A Request is always followed by a Reply from the host owning that IP
- Responses are cached in the ARP table — no persistent authentication exists
- ARP operates at Layer 2 — completely trusts the sending host's claim of MAC/IP mapping

Suspicious Indicators & Attack Patterns

ARP Sweep / Network Scanning [HIGH]

An unusually high volume of ARP Requests issued in a short window, especially with sequential, incrementing IP addresses (e.g. 192.168.1.3 → .4 → .5 → .6). Human users do not generate this pattern — it is characteristic of automated scanning tools mapping live hosts on the subnet. The regularity of the IP increments is the defining anomaly; normal traffic has no such ordering.

ARP Spoofing / Cache Poisoning (Man-in-the-Middle) [CRITICAL]

Attacker sends unsolicited Gratuitous ARP Replies — ARP Reply packets that no host requested. These overwrite legitimate MAC-IP mappings in the ARP cache of target devices. Once poisoned, a victim device sends traffic destined for the gateway or another host directly to the attacker's MAC. The attacker forwards the traffic onward (staying invisible) while capturing everything in transit. Entire sessions — including credentials — can be intercepted.

MAC Spoofing [HIGH]

Two ARP entries in the table show the same MAC address but different IP addresses. This indicates a device is impersonating another host on the network. In conjunction with ARP poisoning, an attacker may clone the MAC of a trusted device to bypass MAC-based access controls (e.g. port security on switches).

- Watch for: ARP Replies arriving without any corresponding ARP Request (gratuitous/unsolicited)
- Watch for: Sequential IP address patterns in ARP requests — .1, .2, .3 monotonic sweep
- Watch for: Duplicate MAC addresses in the ARP cache with different assigned IPs
- Watch for: Sudden changes to the MAC address associated with the default gateway

2.3. ICMP — Internet Control Message Protocol

Packet Structure

Field	Description	Key Values
Type	Category of the ICMP message	0=Echo Reply, 3=Dest Unreachable, 5=Redirect, 8=Echo Request, 11=TTL Exceeded, 12=Param Problem
Code	Sub-type providing additional error context	Varies by Type — e.g. Type 3 Code 0=Net Unreach, Code 1=Host Unreach, Code 3=Port Unreach
Checksum	16-bit integrity check over ICMP header + data	Detects corruption in transit
Header Info	Context-dependent field (Identifier + Sequence)	Echo Request/Reply: Identifier links request to reply; Sequence increments per ping
Data	Variable payload — random by default in Echo messages	Key forensic field — can carry exfiltrated content in covert channel attacks

Normal Behaviour

- Echo Request (Type 8, Code 0) is paired with Echo Reply (Type 0, Code 0)
- Data field in a normal ping contains a random value — this exact value is mirrored in the reply
- Each request-reply pair shares an Identifier value; Sequence number increments with each ping
- ICMP operates at the IP layer (Layer 3) — it has no port number

Suspicious Indicators & Attack Patterns

ICMP Data Exfiltration (Covert Channel) [HIGH]

The Data field of ICMP Echo packets is arbitrary — an attacker can encode stolen data (credentials, files, database records) inside ping packets. Since ICMP is rarely inspected by firewalls and IDS rules often ignore the payload, this creates a stealthy outbound channel. Indicators: ICMP data fields significantly larger than the standard 32-56 bytes, or data with high entropy (compressed/encrypted content). Malware families including Gh0st RAT and tools like icmpsh use this technique.

Ping Flood (ICMP DoS) [HIGH]

Overwhelming a target with a high volume of ICMP Echo Requests, forcing it to consume CPU and bandwidth responding. Each request requires the host to generate a reply — at sufficient volume, legitimate traffic is starved. Amplification variants use broadcast addresses to multiply the effect. Indicator: thousands of ICMP packets per second from one or few source IPs.

Unsolicited External ICMP Replies (Reconnaissance) [MEDIUM]

Receiving ICMP responses from external hosts when no outbound requests were made from internal hosts. This indicates an external party is sending crafted ICMP packets to probe the network — active host discovery and topology mapping. Often a precursor to a targeted attack. Also watch for ICMP Redirect (Type 5) messages which can manipulate routing tables.

- Watch for: ICMP Echo packets with data sections exceeding 100 bytes — likely covert channel
- Watch for: ICMP packet rates exceeding normal baseline — DoS in progress
- Watch for: Incoming ICMP replies with no corresponding outbound request in state tables
- Watch for: ICMP Redirect (Type 5) messages — can silently alter routing

2.4. TCP — Transmission Control Protocol

Packet Structure

Field	Size	Description
Source Port	16 bits	Sending application's port number
Destination Port	16 bits	Receiving application's port number
Sequence Number	32 bits	Random initial value; increments by bytes transmitted — tracks data ordering
Acknowledge Number	32 bits	Next expected byte from sender; starts at 0, increments by bytes received
Header Length	4 bits	Length of TCP header in 32-bit words (typically 5 = 20 bytes)
Control Flags	6 bits	URG, ACK, PSH, RST, SYN, FIN — manage connection state and data flow
Window Size	16 bits	Number of bytes receiver is willing to accept (flow control)
Checksum	16 bits	Integrity check over TCP header and data
Urgent Pointer	16 bits	Offset to urgent data end — only valid when URG flag is set
Options	0-40 bytes	MSS, SACK, Window Scaling — negotiated during handshake for performance
Data	Variable	Application payload — only present in data-carrying segments

TCP Control Flags Reference

Flag	Bit	Purpose	Suspicious Usage
SYN	Bit 1	Initiate connection — synchronise sequence numbers	SYN flood, SYN scan — sent without completing handshake
ACK	Bit 4	Acknowledge receipt of data	ACK scan — sent without prior SYN to probe firewall rules
FIN	Bit 0	Gracefully terminate connection	FIN scan — probes ports stealthily on some OS implementations
RST	Bit 2	Abruptly reset an active connection	TCP RST Attack — spoofed RST to kill sessions between two hosts
PSH	Bit 3	Push data to application immediately, bypass buffer	Unusual alone without data — may indicate manipulation
URG	Bit 5	Mark urgent data pointer as valid	Rarely used legitimately — seen in some evasion and DoS techniques
NULL	None set	No flags — invalid state	NULL scan — used for stealth port scanning and OS fingerprinting
XMAS	FIN+PSH+URG	All three set — invalid/unusual	XMAS scan — elicits RST from closed ports to map services

Normal Behaviour — 3-Way Handshake

- SYN: Client sends SYN with a random initial Sequence number (ISN), ACK = 0
- SYN/ACK: Server responds with its own random ISN, ACK = Client ISN + 1
- ACK: Client confirms with ACK = Server ISN + 1. Connection established.
- TCP handshake is strictly between exactly two hosts — never multicast or broadcast
- FIN-ACK exchange is the legitimate, graceful way to terminate a connection

Suspicious Indicators & Attack Patterns

SYN Flood (DoS / DDoS) [CRITICAL]

Attacker sends millions of SYN packets with spoofed source IPs, forcing the server to allocate memory for half-open connections and respond with SYN/ACK to addresses that never complete the handshake. The server's connection table fills up — legitimate connections are rejected. Modern variants use botnets to send SYNs from real IPs at massive scale. Indicator: extremely high SYN rate, near-zero completed handshakes, server resource exhaustion.

SYN/Port Scanning [HIGH]

One host sends SYN packets to multiple ports or multiple destination hosts in rapid succession. Never completes the handshake. Purpose: identify open ports and live hosts before launching an attack. Metasploit and Nmap both use this technique. Port 4444 appearing as a destination is a direct Metasploit indicator — it is the default listener port for Meterpreter payloads.

TCP RST Attack (Session Termination) [HIGH]

Attacker spoofs the IP of one participant in an active TCP session and sends a RST packet, instantly terminating the connection. Detection signature: two hosts communicating have different MAC addresses but one of them shares an IP address with a third device — the MAC/IP inconsistency reveals the spoofed RST source. Can be used to disrupt VPN tunnels, BGP sessions, or active monitoring connections.

TCP Hijacking (Session Takeover) [CRITICAL]

After observing sequence numbers in an active TCP session, an attacker injects packets with the correct sequence numbers to take over the session mid-stream. The legitimate host experiences TCP retransmissions as its packets appear to be duplicates. Indicator: unexpected TCP retransmission events, sequence number anomalies, sudden changes in session behaviour without FIN/RST.

- Watch for: SYN packets with no corresponding SYN/ACK or ACK completions
- Watch for: One source IP sending to many ports — automated scanning in progress
- Watch for: Port 0 (invalid) or port 4444 (Metasploit default) in connections
- Watch for: RST packets from an IP whose MAC doesn't match the ARP table entry
- Watch for: TCP retransmission events in otherwise stable connections — potential hijacking
- Watch for: NULL, XMAS, FIN-only scan patterns — evasion techniques

2.5. UDP — User Datagram Protocol

Packet Structure

Field	Size	Description
Source Port	16 bits	Sender's port — can be 0 if reply is not required
Destination Port	16 bits	Receiving service's port
Datagram Length	16 bits	Total length of header + data in bytes (minimum 8 bytes — header only)
Checksum	16 bits	Error detection over header and data — optional in IPv4, mandatory in IPv6
Data	Variable	Application payload

Normal Behaviour

- Connectionless — no handshake, no guaranteed delivery, no ordering
- Used where speed matters more than reliability: VoIP (Skype, Zoom), gaming, IoT, DNS, NTP
- Small header overhead (8 bytes vs TCP's 20+ bytes) makes it efficient for high-frequency low-latency applications
- Absence of connection state means inherently fewer attack surfaces than TCP

Suspicious Indicators & Attack Patterns

UDP Port Scan [HIGH]

Attacker sends UDP packets to many different ports on a target. Closed ports respond with ICMP Type 3 (Destination Unreachable) messages. By collecting these ICMP responses, the attacker maps which ports are open (no response = likely open/filtered) vs closed. Indicator: burst of UDP packets to sequential or scattered ports combined with a corresponding wave of outbound ICMP unreachable responses.

UDP Flood (DoS) [HIGH]

Attacker sends massive volumes of UDP packets to random unused ports on the target. The server is forced to generate an ICMP Destination Unreachable response for every packet hitting a closed port, consuming bandwidth and CPU. The attacker uses a spoofed source IP so the flood of ICMP bounce-back responses hits the spoofed victim (amplification) rather than the attacker. The target server becomes unavailable to legitimate clients.

C&C Beaconing via DNS/UDP [HIGH]

Malware sends periodic DNS queries (UDP) to its Command and Control server — but receives no DNS reply. This silent one-way communication is the malware 'checking in' and receiving instructions encoded in the DNS response fields. Indicator: recurring DNS requests from the same internal host to unusual external domains with no response, or responses with abnormally long TTLs.

- Watch for: Spike in outbound ICMP Destination Unreachable messages — UDP port scan in progress
- Watch for: UDP packets to many ports from a single source in a short window
- Watch for: Recurring DNS UDP queries with no corresponding replies — C&C beacon
- Watch for: Unusual source port 0 in UDP — invalid, indicates crafted/malicious packets

2.6. DNS — Domain Name System

Packet Structure

Field	Description
DNS ID / Transaction ID	16-bit unique identifier — query and its response share the same ID
QR (Query/Response)	1 bit: 0 = Query, 1 = Response
OPCODE	4 bits: 0 = Standard Query, 1 = Inverse Query, 2 = Server Status
AA (Authoritative Answer)	1 bit: set in responses from authoritative name servers for the queried domain
TC (Truncation)	1 bit: response was truncated — full answer exceeds UDP capacity (>512 bytes), retry over TCP
RD (Recursion Desired)	1 bit: client requests recursive resolution if server doesn't have the answer locally
RA (Recursion Available)	1 bit: set in response if the server supports recursive queries
Z (Reserved)	3 bits: must be zero — extensions used for DNSSEC (AD, CD flags)
RCode (Response Code)	4 bits: 0=No Error, 1=Format Error, 2=Server Failure, 3=NXDOMAIN, 5=Refused
Question Count	Number of entries in the Question Section (typically 1)
Answer Count	Number of Resource Records in the Answer Section
Authority RR Count	Number of name server records in the Authority Section
Additional RR Count	Number of supplemental records in the Additional Section
Questions Section	Name field (domain queried) + Type field (A, AAAA, MX, TXT, AXFR, etc.)
Answers Section	Resource Records answering the query — can contain multiple RRs
Authority Section	Referral to authoritative name servers for continued resolution
Additional Section	Supplementary records (e.g. A records for name servers listed in Authority)

Normal Behaviour

- Standard queries use UDP port 53 — fast, connectionless, suitable for small query/response pairs
- Every DNS query and its corresponding reply share the same Transaction ID
- DNS queries are sent to the configured DNS server (local resolver or ISP/corporate DNS)
- Recursive queries: when the resolver doesn't have the answer, it queries upstream — this secondary query gets a NEW Transaction ID
- Typical response size: under 512 bytes for UDP; larger responses trigger TCP fallback

Suspicious Indicators & Attack Patterns

DNS Zone Transfer Abuse (AXFR/IXFR) [CRITICAL]

DNS Zone Transfer is a legitimate mechanism for primary→secondary DNS server synchronisation, using TCP port 53 (responses too large for UDP). AXFR transfers the entire zone; IXFR transfers only changes. The critical vulnerability: no authentication and no encryption are required. An attacker who sends an AXFR request to a misconfigured DNS server receives a complete dump of every hostname, IP, and service in the organisation's DNS — a full infrastructure map. Mitigation: restrict zone transfers to trusted IP addresses only, use TSIG signatures, or disable AXFR entirely.

DNS Tunneling (Data Exfiltration) [CRITICAL]

Data is encoded into DNS query strings (subdomains) and sent to an attacker-controlled domain. The attacker's authoritative name server extracts the encoded data from the query. Responses can carry encoded commands back. Because DNS traffic crosses almost every firewall without inspection, it is one of the most robust exfiltration channels available. Indicators: one client generating abnormally large or frequent DNS queries, unusually long subdomain labels, high-entropy subdomain strings, queries to domains not matching the organisation's normal DNS usage.

DGA — Domain Generation Algorithm (C&C Infrastructure) [HIGH]

Malware generates pseudo-random domain names daily using a seed algorithm. The malware queries these domains to reach its C&C server. Even if one domain is blocked, hundreds of others are generated. Indicators: DNS queries to high-entropy, non-sensical domain names (e.g. xk9mzpq3.com, bvt7lra.net) with no corresponding legitimate business purpose. Clustering these queries by source host reveals infected machines.

Fake DNS Server / DNS Spoofing [CRITICAL]

An attacker either stands up a rogue DNS server on the network or poisons the DNS cache of a resolver. Clients receive falsified IP addresses for legitimate domain names and are redirected to attacker-controlled servers — credential harvesting, MITM, or malware delivery. Detection: compare the IP of the responding DNS server against the authorised server list. Mismatched DNS server IPs are an immediate indicator of compromise.

- Watch for: TCP on port 53 originating from non-approved IPs — potential zone transfer exfiltration
- Watch for: DNS queries significantly larger than normal baseline — tunneling
- Watch for: High-entropy, random-looking domain names queried repeatedly from same host
- Watch for: Many DNS requests with no corresponding replies — or floods of NXDOMAINs from DGA
- Watch for: DNS responses from IPs not matching Victim configured nameservers

○ 2.7. HTTP — Hypertext Transfer Protocol

Packet Structure

Component	Description
Request Line	Method (GET/POST/PUT/DELETE/HEAD) + Requested URL + HTTP Version
Request Headers	Accept, Accept-Language, User-Agent, Accept-Encoding, Connection — metadata about client capabilities
Request Body	Optional — used in POST/PUT; carries form inputs, JSON payloads, file uploads
Response Line	HTTP Version + Status Code (200/301/403/404/500) + Status Phrase
Response Headers	Date, Server, Content-Type, Content-Length, Last-Modified — metadata about the response
Response Body	The actual content returned: HTML, JSON, file, etc.

HTTP Status Code Reference

Code Range	Meaning	Security Relevance
2xx — Success	Request successfully received, understood, accepted	Baseline normal; 200 OK most common
3xx — Redirect	Client must take additional action	301/302 redirects can be abused in phishing chains
4xx — Client Error	Request contains bad syntax or cannot be fulfilled	403 = access denied; 404 floods = scanning; 401 floods = brute force
5xx — Server Error	Server failed to fulfil a valid request	500 spikes after injection attempts = successful error-triggering

Normal Behaviour

- HTTP operates over TCP on port 80, 8080, or 8088
- All content is transmitted in plaintext — every header, URL, and body is visible on the wire
- Requests use Fully Qualified Domain Names (FQDN) — hostname + domain (e.g. www.company.com)
- User-Agent reflects the client browser or application legitimately making the request

Suspicious Indicators & Attack Patterns

Web Application Attacks (SQLi, XSS, LFI/RFI, IDOR, Code Injection) [CRITICAL]

Attack patterns are visible in URL parameters and request bodies. SQL Injection: ' OR 1=1--, UNION SELECT patterns in GET/POST parameters. XSS: <script> tags, javascript: URIs in input fields. LFI: ../../etc/passwd path traversal. RFI: http:// URLs in file include parameters. IDOR: sequential numeric IDs in REST endpoints (/user/1001, /user/1002). Code Injection: system(), exec() calls in parameters. All visible as plaintext in HTTP logs.

Automated Attack Tool Signatures [HIGH]

Automated tools leave traces in the User-Agent header. Examples: 'sqlmap/1.x' (SQL injection), 'Nikto/2.x' (web scanner), 'DirBuster' (directory enumeration), 'Hydra' (brute force), custom or blank user-agents. Legitimate browsers always present identifiable user-agent strings. Missing, generic, or tool-named user-agents are immediate red flags requiring investigation.

Data Exfiltration via HTTP Outbound [HIGH]

High-volume outbound HTTP traffic where the request sizes or POST bodies are abnormally large. An internal host making frequent large POST requests to an external server is a common exfiltration pattern. Timing anomalies also indicate automated exfiltration — HTTP traffic at 3AM in a corporate environment has no legitimate explanation and warrants immediate investigation.

DoS / Brute Force via HTTP Flood [HIGH]

Thousands of HTTP requests per second to a web server (HTTP Flood DoS) or to a login endpoint (Brute Force). Brute force indicators: many POST requests to /login, /admin, /wp-login.php with varying credentials but same source IP. HTTP DoS: uniform requests at machine speed, no pause between requests, often sourced from multiple IPs (DDoS).

- Watch for: IP addresses in HTTP Host header instead of FQDN — could bypass hostname-based controls
- Watch for: .exe, .zip, .bat, .ps1 file extensions in URLs — malware download attempt
- Watch for: Encrypted content in HTTP (not HTTPS) — web shell hiding malicious code
- Watch for: Tool names in User-Agent — sqlmap, Nikto, DirBuster, Hydra, curl in automated scanning
- Watch for: 404 flood followed by a 200 — successful directory enumeration leading to resource discovery
- Watch for: Large outbound POST payloads to external IPs during off-hours

2.8. SSL / TLS — Secure Sockets Layer / Transport Layer Security

SSL Architecture

SSL Sub-Protocol	Function
Handshake Protocol	Establishes the secure session: negotiates cipher suites, authenticates the server (and optionally client), exchanges keys
Change Cipher Spec Protocol	1-byte message (value=1) signalling that subsequent records will use the newly negotiated cipher suite
Alert Protocol	Reports errors and warnings: Warning (level 1) or Fatal (level 2). Fatal alerts terminate the connection immediately
Record Protocol	Fragments, compresses, encrypts, and transmits data from higher layer protocols; provides confidentiality and integrity

SSL Alert Protocol — Warning vs Fatal

Level	Alert Name	Meaning
Warning (1)	close_notify	Sender is closing the connection — graceful shutdown
Warning (1)	bad_certificate	Certificate is corrupt or in an unexpected format
Warning (1)	unsupported_certificate	Certificate type not supported by the receiver
Warning (1)	certificate_revoked	Certificate has been revoked by its issuing CA
Warning (1)	certificate_expired	Certificate's validity period has elapsed
Fatal (2)	handshake_failure	Cannot agree on cipher parameters — connection aborted
Fatal (2)	bad_record_mac	Integrity check (MAC) failed — data tampered in transit
Fatal (2)	decompression_failure	Data could not be decompressed — malformed or corrupted
Fatal (2)	illegal_parameters	Field in handshake is out of range or inconsistent

TLS Handshake Sequence

Step	Direction	Content	Security Purpose
1. Client Hello	Client → Server	TLS version, Client Random (32-bit), Session ID, Cipher Suites list, Compression methods, Extensions	Initiates negotiation; Client Random prevents replay attacks
2. Server Hello	Server → Client	Selected TLS version, Server Random, Session ID, Chosen Cipher Suite, Chosen Compression	Server locks in negotiated parameters
3. Server Certificate	Server → Client	X.509 certificate: hostname, public key, CA signature, validity dates	Client verifies server identity via trusted CA chain

Step	Direction	Content	Security Purpose
4. Server Key Exchange	Server → Client	Ephemeral public key (for ECDHE/DHE), signature over key + both Randoms	Provides forward secrecy — session key not derivable from long-term private key
5. Server Hello Done	Server → Client	Empty message — signals end of server's handshake messages	Client can now proceed with key exchange
6. Client Key Exchange	Client → Server	PreMaster Secret encrypted with server public key (RSA) or client's ephemeral key (DHE)	Establishes shared session key material
7. Change Cipher Spec	Both directions	1-byte signal: switch to negotiated cipher	Activates encryption for all subsequent traffic
8. Finished	Both directions	Hash of all handshake messages encrypted with session key	Verifies handshake integrity — detects MITM tampering
9. Application Data	Both directions	Encrypted application data (HTTP, etc.)	Actual protected communication begins

2.9. HTTPS — HTTP Secure

Normal Behaviour

- HTTPS = HTTP transported over a TLS-encrypted channel
- Operates on TCP port 443 (standard) or 8443 (alternative)
- Every HTTPS session must begin with a complete TLS handshake before any data flows
- Certificate hostname in the certificate's CN/SAN field must match the requested domain
- Certificate must be signed by a trusted CA and must not be expired or revoked
- All application data (HTTP headers, body, URL path) is encrypted — only the destination IP/port and SNI (Server Name Indication) are visible to a passive observer

Suspicious Indicators & Attack Patterns

Missing TLS Handshake / Malformed HTTPS [CRITICAL]

HTTPS traffic arriving on port 443 without a preceding TLS ClientHello handshake is a serious anomaly. This can indicate a deliberately crafted raw TCP stream attempting to exploit a server vulnerability before TLS negotiation, or a misconfigured tool sending unencrypted HTTP to an HTTPS port. Either way: no legitimate HTTPS communication skips the handshake.

Certificate Anomalies (Expired, Self-Signed, Untrusted CA) [HIGH]

Three distinct certificate red flags: (1) Expired certificate — the server failed to renew, or an attacker is reusing an old cert in a phishing setup. (2) Self-signed certificate — no CA has vouched for this server's identity; common in internal lab environments but suspicious on public-facing or unknown hosts. (3) Untrusted CA — certificate signed by a CA not in the trusted store; attacker has set up their own CA to sign fraudulent certificates for MITM attacks.

Certificate Hostname Mismatch [CRITICAL]

The domain name in the URL (or TLS SNI extension) does not match the Common Name or Subject Alternative Name in the server's certificate. This is the classic indicator of SSL stripping attacks, MITM proxies, or phishing infrastructure impersonating legitimate services. A browser would show a certificate warning — an attacker hopes the victim ignores it or that the target is automated software that skips verification.

Spurious Retransmission + ZeroWindow (Ransomware Staging) [CRITICAL]

Spurious Retransmission: the client resends a packet it already sent because it believes the server didn't receive it — but the server did. This appears during ransomware exfiltration when the malware is aggressively pushing encrypted stolen data faster than the network can absorb it. ZeroWindow: the receiver's TCP buffer is full and it signals the sender to stop. Together, these two events during an HTTPS session to an unknown external host strongly suggest active data exfiltration or ransomware beacon traffic. Correlate with endpoint forensics immediately.

C&C Server Over HTTPS (Port 443) [HIGH]

Modern malware routes its Command & Control traffic over HTTPS to blend with legitimate web traffic. Port 443 is rarely blocked by firewalls. Indicators: internal hosts making HTTPS connections to unusual, low-reputation, or recently registered domains; connections to IPs without a valid hostname (direct IP HTTPS); anomalous connection frequency (e.g. precise 60-second intervals = beacon timing); traffic to CDN-hosted C&C infrastructure (Cloudflare, AWS being abused).

- Watch for: Port 443 traffic with no TLS handshake — raw TCP or malformed stream
- Watch for: Empty SSL/TLS record headers — crafted packets testing for implementation bugs
- Watch for: Self-signed or expired certificates on external-facing hosts Victim didn't provision
- Watch for: CN/SAN hostname mismatch — SSL stripping or MITM proxy
- Watch for: Oversized TLS Application Data records — malware payload or data exfiltration
- Watch for: Spurious Retransmission events during HTTPS to unknown external IPs — ransomware
- Watch for: Precise interval beaconing on port 443 — C&C communication
- Watch for: HTTPS connections to IPs with no reverse DNS or to recently registered domains

3. Cross-Protocol Attack Chains

Real-world attacks rarely exploit a single protocol in isolation. Adversaries chain protocol weaknesses across multiple layers to achieve their objectives. Understanding these chains enables defenders to detect campaigns at earlier stages.

Chain 1: Network Takeover via DHCP + ARP

Stage	Protocol	Technique	Objective
1	DHCP	DHCP Starvation — exhaust IP pool with spoofed MAC requests	Deny network access to legitimate devices
2	DHCP	Rogue DHCP Server — serve malicious gateway/DNS	Redirect all client traffic through attacker
3	ARP	Gratuitous ARP poisoning of gateway entry	Ensure traffic routes to attacker even if legitimate DHCP recovers
4	TCP/HTTP/HTTPS	MITM interception, credential capture	Harvest credentials, inject malicious content

Chain 2: Reconnaissance to Exploitation via ICMP + TCP

Stage	Protocol	Technique	Objective
1	ICMP	Ping sweep — send Echo Requests to IP range	Discover live hosts on the network
2	TCP	SYN scan across live hosts — probe all ports	Map open services on discovered hosts
3	TCP	Targeted exploit to open service (e.g. port 445, 3389)	Gain initial access to a vulnerable host
4	ICMP	ICMP covert channel from compromised host	Exfiltrate data, maintain C&C under radar

Chain 3: Malware Persistence via DNS + HTTPS

Stage	Protocol	Technique	Objective
1	DNS	DGA — malware queries auto-generated domains	Locate active C&C server even after domain takedowns
2	HTTPS	C&C communication over port 443 to DGA domain	Receive commands, blend with normal traffic
3	DNS	DNS Tunneling for data exfiltration	Extract stolen data encoded in DNS queries
4	HTTPS	Ransomware payload delivered via HTTPS download	Deploy encryption payload to victim
5	HTTPS	Spurious Retransmission during exfil	Exfiltrate before encrypting files

4. SOC Detection Quick Reference

Use this table as a rapid-triage reference when reviewing packet captures or SIEM alerts. Each row maps an observable IOC to its likely attack scenario and recommended action.

Proto	Observable IOC	Likely Attack	Recommended Action
DHCP	Mass Discover pkts, varied MACs	DHCP Starvation → Rogue DHCP	Block unknown DHCP servers; check switch port security
ARP	Gratuitous ARP replies, no request	ARP Spoofing / MITM	Enable Dynamic ARP Inspection on switches
ARP	Duplicate MAC, different IPs	MAC Spoofing	Correlate with port security logs; isolate port
ICMP	Large ICMP data payload	Data exfiltration covert channel	Inspect ICMP payload; block abnormal sizes
ICMP	External ICMP replies, no outbound req	External reconnaissance	Block unsolicited inbound ICMP at perimeter
TCP	SYN flood, no ACK completions	SYN Flood DoS	Enable SYN cookies on servers; rate-limit SYNs
TCP	Port 4444 connections	Metasploit Meterpreter	Isolate host; begin IR process immediately
TCP	RST from IP with mismatched MAC	TCP RST Attack	Verify ARP table integrity; investigate spoofed host
TCP	Unexpected retransmissions	TCP Hijacking	Capture full session; check sequence anomalies
UDP	ICMP unreachable spike	UDP Port Scan	Block scanning source; review firewall ACLs
DNS	TCP port 53 from unknown IP	Zone Transfer attempt	Restrict AXFR to authorised IPs only; alert SOC
DNS	High-entropy domain queries	DGA / DNS Tunneling	Block domain; isolate host; investigate malware
DNS	Oversized DNS queries	DNS Tunneling exfil	Baseline DNS query sizes; alert on anomalies
HTTP	sqlmap/Nikto in User-Agent	Web app attack scan	Block IP; review web server logs for successful hits
HTTP	.exe/.zip in URL, off-hours	Malware download	Block URL; check endpoint for execution
HTTP	Mass POST to login endpoint	Brute Force attack	Implement rate limiting and CAPTCHA; block IP
HTTPS	No TLS handshake on port 443	Crafted exploit / probe	Block source; inspect raw TCP stream
HTTPS	Cert hostname mismatch	SSL MITM / phishing	Terminate connection; alert user; investigate proxy
HTTPS	Spurious Retransmit + ZeroWindow	Ransomware exfiltration	ISOLATE HOST IMMEDIATELY; begin IR

Proto	Observable IOC	Likely Attack	Recommended Action
HTTPS	Precise-interval port 443 traffic	C&C beaconing	Block domain/IP; isolate host; full IR

5. Key Analytical Insights

5.1 The Trust Problem — Why These Protocols Are Exploitable

A recurring theme across DHCP, ARP, ICMP, and DNS is the absence of authentication. These protocols were designed in an era when network participants were assumed to be trustworthy. DHCP does not verify that a MAC address belongs to the device claiming it. ARP has no mechanism to validate that a MAC-IP mapping is legitimate. ICMP accepts data payloads from any source without validation. DNS zone transfers have no mandatory authentication requirement. This architectural reality means defenders cannot rely on the protocol itself to detect abuse — they must monitor behaviour at the network level.

5.2 The Encryption Paradox in HTTPS

HTTPS protects users from network-level eavesdropping. However, it simultaneously provides attackers with a high-trust evasion channel. C&C traffic, ransomware exfiltration, and malware downloads all benefit from encryption. This creates a fundamental tension for defenders: decrypting HTTPS for inspection (SSL/TLS inspection) introduces its own risks (certificate mismatch, privacy concerns, performance) while not doing so leaves a major blind spot. Behavioural indicators — beacon timing, certificate anomalies, connection volume — become the primary detection surface.

5.3 Protocol Layering Creates Detection Opportunities

Attacks rarely stay within a single protocol layer. UDP port scans generate ICMP responses. DNS tunneling rides on UDP. TCP hijacking affects application-layer sessions. This layering means that even when an attacker carefully crafts their primary attack vector, their activity produces artefacts in adjacent protocols. A UDP scan creates a spike in outbound ICMP unreachable messages. A DHCP starvation attack leaves ARP table anomalies. Defenders who correlate across protocol layers catch attacks that single-protocol analysis misses.

5.4 Timing and Volume as Primary IOC Dimensions

Across every protocol analysed, volume and timing are the most reliable detection dimensions. Normal human network behaviour is irregular — bursty, contextual, bounded by working hours. Attacks are often systematic — sequential, high-volume, precisely timed, operating outside business hours. DHCP starvation is characterised by volume. SYN scans are characterised by sequential targeting. C&C beaconing is characterised by precise timing intervals. Building a behavioural baseline of normal traffic volume and timing patterns per protocol is the foundation of effective anomaly detection.

5.5 Sequence and State Violations as Attack Signatures

Each protocol defines a valid state machine — DHCP's DORA, TCP's three-way handshake, TLS's handshake sequence, DNS's query-response pairing. Attacks almost universally violate these sequences: gratuitous ARP replies with no request, TCP RST packets with no prior session, HTTPS traffic with no TLS handshake, DNS responses without a matching query. Monitoring for state sequence violations is one of the most reliable detection strategies available, because attackers cannot achieve their objectives while fully respecting the protocol's state machine.

6. Conclusion

Every byte on the network follows rules. Attackers succeed not by breaking those rules outright, but by bending them — using valid packet structures to carry malicious intent, exploiting unauthenticated trust, and hiding in the volume and complexity of legitimate traffic. The 10 protocols documented here form the substrate of virtually every enterprise network interaction. A SOC analyst who can read their state sequences, spot their anomalies, and trace their attack patterns across layers holds a decisive advantage.

The critical principle: no protocol should be trusted in isolation. Correlate DHCP events with ARP tables. Correlate DNS anomalies with network flow data. Correlate HTTPS certificate alerts with endpoint telemetry. The attack is always in the relationship between events — not in any single packet.

— *End of Analysis Document* —

1- DHCP

Structure:

Offsets	Octet	0	1	2	3
Octet	Bit	0-7	8-15	16-23	24-31
0	0	OpCode	Hardware Type	Hardware Length	Hops
4	32	Transaction ID			
8	64	Seconds Elapsed		Flags	
12	96	Client IP Address			
16	128	Your IP Address			
20	160	Server IP Address			
24	192	Gateway IP Address			
28	224	Client IP Address			
32	256	Client Hardware Address (16 bytes)			
36	288				
40	320				
44	352				
48+	384+	Server Host Name (64 bytes)			
		Boot File (128 bytes)			
		Options			

OPCODE: Tells us the type of the packet if it is request or reply

Hardware type: the type of hardware address, Ex: Ethernet, IEEE802, ATM

Hardware length: the length of the hardware address

Hops: Hops or routers which help in finding a DHCP server

Transaction ID: Random number, it is unique for request and its response

Seconds Elapsed: no of Seconds started when the client first requested an address from the DHCP server

Flags: The type of traffic the DHCP client can accept. (unicast, broadcast)

Client IP Address: The client's new IP address from Offer message.

Your IP Address: The IP address offered by the DHCP server

Server IP Address: The DHCP server's IP address

Gateway IP Address: The IP address of the network's default gateway

Client Hardware Address: The client's MAC address

Server Host Name: (optional) The server's host name

Boot File: (optional) A boot file for use by DHCP

Options: Used to expand the structure of the DHCP with more features.

1: Subnet mask	15: Domain name
3: Router	31: Router discovery
4: Time server	50: Requested IP address
5: Name server	53: DHCP message type
6: Domain server	54: DHCP server identifier (IP)
12: Host name	255: end

Normal:

- It's referenced to BOOTP protocol which is client/server protocol
- Transaction id is unique for the request and its response
- Notice the natural sequence of DHCP messages (D,O,R,A)
- For Discover message,
 - Source and client IP is 0.0.0.0
 - Destination IP is 255.255.255.255 (broadcast)
- For Offer and Ack messages,
 - Source IP is (DHCP server IP)
 - Client IP is (New IP obtained)
 - Destination IP is 255.255.255.255 (broadcast)
- For Request message,
 - Source IP is 0.0.0.0
 - Client IP is (New IP obtained)
 - Destination IP is 255.255.255.255 (broadcast)
- Uses UDP on port 67 if server, 68 if client

Suspicious: Huge number of DHCP requests from different and suspicious IP addresses (DHCP starvation) or spoofed DHCP IP address.

2- ARP

Structure:

Hardware type (2 bytes)		Protocol type (2 bytes)
Hardware address length (1 byte)	Protocol address length (1 byte)	Operation code (2 bytes)
Source hardware address*		
Source protocol address*		
Target hardware address*		
Target protocol address*		

Hardware type: the type of hardware address, Ex: Ethernet, IEEE802, ATM

Protocol type: the type of protocol (IPv4 or IPv6)

Hardware length: the length of the hardware address

Protocol length: the length of the IP address

Operation code: (1) for ARP request, (2) for ARP reply

Source hardware address: sender mac address

Source protocol address: sender IP address

Target hardware address: receiver mac address

Target protocol address: receiver IP address

Normal:

- A normal ARP Request typically follows a response
- Target mac address is FF:FF:FF:FF:FF:FF in the ARP request message

Suspicious:

- Huge number of ARP requests in small time (ARP sweep)
- ARP requests come from suspicious IPs that are not seem to be real.
Ex: 192.168.1.3, 192.168.1.4, 192.168.1.5, 192.168.1.6, ... (Notice that the number is increased by one, this is not usual behavior)
- Notice Mac spoofing which means there are 2 identical mac address with different Ips.
- ARP replay without ARP request (ARP spoofing using gratuitous ARP reply)

3- ICMP

Structure:

Bit 0–7	Bit 8–15	Bit 16–23	Bit 24–31
Type	Code	Checksum	
Header Information			

Type: Tells us the description of the message

0: Echo reply.

8: Echo Request.

3: Destination unreachable.

11: Time Exceeded.

5: Redirect Message.

12: Parameter problem.

Code: tells us information about error message and type

Checksum: message integrity check, it detects whether any error exists in the message or not.

Header Information: Information about the message depend on reply type

Normal:

- Echo request has **code: 0** and **Type: 8**
- Notice **Data** section which has a random value, this random value is unique for request and its reply

Suspicious:

- The Data section can be used as exfiltration channel.
- The number of sent packets. (ping flood) (DOS)
- Notice any ICMP response from external network you did not make as it could be part of reconnaissance plan.

4- TCP

Structure:

Source port (16 bits)					Destination port (16 bits)				
Sequence number (32 bits)									
Acknowledge number (32 bits)									
Header Length (4 bits)	Reserved bits (4 bits)	U R G	A C K	P S H	R S T	S Y N	F Y N	Windows size (Advertisement window 16 bit)	
Checksum (16 bits)					Urgent pointer (16 bits)				
Option (0-40 bits)									
Data optional									

Source port: the source/transmitting application's port number.

Destination port: the port number of the receiving application.

Sequence number: random value which starts the connection and is increased according to the number of the transmitted bytes.

Acknowledge number: starts with zero by the receiving side and is increased according to the number of bytes received.

Header length/TCP data offset: the length of the header.

Control flags: help in managing data flow in specific situations.

- **URG/Urgent:** urgent pointer tells us that the data should be treated as priority over other data.
- **ACK/Acknowledgment:** to make sure that the receiver has received the data by sending an acknowledgment.
- **PSH/Push:** tells an application that the data should be transmitted immediately and we don't want to wait to fill the entire segment.

- **RST/Reset:** Reset the connection when an error occurs. This is not a normal way to finish the connection.
- **SYN/Synchronize:** start, synchronize the connection between sender and receiver by setting a sequence number for the connection.
- **FIN/Finish:** when the connection is terminated.

Window size: tells us how many bytes the receiver wants to receive.

Checksum: tells us if the header is damaged during connection.

Urgent pointer: used when the URG bit has been set, and it is used to indicate where the urgent data ends.

Option: These are optional fields for setting maximum segment sizes, selective acknowledgments and enabling window scaling for more efficient use of high-bandwidth networks.

Data: the application data that is transmitted.

Normal:

- Normal 3-way handshake (SYN-SYN/ACK-ACK)
 - SYN ? Seq: random number ex:1, ACK= 0
 - SYN/ACK ? Seq: random number ex:4, ACK= Seq+1, 1+1=2
 - ACK ? Seq: ACK=2, ACK= Seq+1, 4+1=5
- TCP 3-way handshake is between 2 hosts only.

Suspicious:

- Huge number of SYN messages in small time. (SYN scan)
- Usage of unusual flags.
- One host send to multiple ports or nodes. (scanning), (SYN flood).
- Usage of unusual port numbers ex:0 or 4444 (Metasploit)
- Using spoofed IP of one of 2 hosts to RST/Reset connection between them. Notice that the 2 hosts have different MAC addresses and one IP address. (TCP RST attack)
- Notice (TCP retransmission) which may points to (TCP Hijacking)

5- UDP

Structure:

Source port (16bit)	Destination port (16bit)
Length (16bit)	Checksum (16bit)
Data (32bit)	

Source port number: the port of the sender and it is considered to be the port to which replies can be sent if it is necessary. If it is not used, it is zero.

Destination port number: the destination port.

Datagram length: the whole size of the header and data.

Checksum: checks for errors and to provide integrity.

Data: the application data.

Normal:

It is used often over VOIP applications (skype, zoom) and gaming. Also with IOT services and any service which are connectionless does not care about orientation, So it does not have this so much vulnerabilities like TCP.

Suspicious:

- Huge number of UDP packets to multiple ports. (port scan)
- It could also be a sign for UDP Flooding which is a type of DOS attack. It is performed by sending huge number of UDP packets to different non used ports (which have no service listening on) of the server which forces it to respond with ICMP (destination unreachable) and this make the system is unavailable for legitimate clients. Notice that the attacker uses spoofed IP address as not to harm themselves by the huge number of the ICMP responds.
- Notice the URL requests with no reply. (C&C exfiltrate data)

6- DNS

Structure:

Offsets	Octet	0	1	2	3
Octet	Bit	0-7	8-15	16-23	24-31
0	0	DNS ID Number		Q R OpCode A A T C R D R A Z RCode	
4	32	Question Count		Answer Count	
8	64	Name Server (Authority) Record Count		Additional Records Count	
12+	96+	Questions Section		Answers Section	
		Authority Section		Additional Information Section	

DNS ID Number: unique number for DNS query and its response

Query/Response (QR): tells us if this packet is a DNS query or response

OPCODE: defines the type of query

Authoritative Answers (AA): If this is set in a response packet, it indicates the response is from a name server with authority over the domain.

Truncation (TC): indicates the response was truncated because it is large.

Recursion Desired (RD): If this is set in a query, it indicates the DNS client requests a recursive query if the target name server doesn't contain the requested information.

Recursive Available (RA): If this is set in a response, it indicates the name server supports recursive queries.

Reserved (Z): defined to be set as all 0s, or as an extension of RCode.

Response Code (RCode): tells us if there are any errors in DNS response.

Question Count / Number of questions: the number of entries in the Question Section.

Answer Count / Number of answer RRs: The number of entries in the Answer Section.

Name Server (Authority) Record Count / Number of Authority RRs: The number of name server resource records in the Authority Section.

Additional Records Count / Number of Additional RRs: The number of other resource records in the Additional Information Section.

Questions Section: contains one or more queries, each query includes:

- 1) name field: contains the name that is being queried.
- 2) type field: indicates the type of question being asked about the name

Answers Section: In a reply packet, it contains one or more RRs that answer queries. A reply can return multiple RRs

Authority Section: contains RRs that point to authoritative name servers that can be used to continue the resolution process

Additional Information Section: contains RRs that hold additional information related to the query that is not absolutely necessary to answer the query.

Normal:

- Using UDP port **53**.
- DNS request and reply have the same Transaction \ DNS ID.
- DNS query is sent to DNS server.
- DNS replies with its requested record.

NOTE:

Recursion: the process of a DNS server queries another DNS server on behalf of the client to find an IP address, acting like a client. This is done when the first server did not find the answer for the request. And this recursive request has a different transaction ID.

Suspicious:

- Many DNS requests with no reply or vice versa
- Using TCP on port 53 instead of UDP
(DNS zone transfer from a suspicious IP address)

NOTE: Organizations usually have more than one DNS server which use them as redundancy and to keep a save copy of DNS records, So they need a total management for these servers as when they change any configuration in one server, they have to implement this change to the other, this what is called DNS zone transfer. When a secondary DNS server requests an update of records from the DNS primary server, it uses AXFR or IXFR to get these updates which uses TCP on port 53 as the respond usually too big to be implemented using UDP and this is the case when we see unique transaction\DNS ID for more than one respond. But this is vulnerable as no authentication or encryption used here. Because of that, organizations usually use trusted IP address only and must be monitored besides using signatures to stop IP spoofing or they block this feature.

- Notice the IP address of DNS server and domain name (fakeDNS)
- Notice the number and size of the query from the client when it is bigger than usual, this is pointer to exfiltration of data using DNS tunneling.
- unusual domain names could be C&C domain generated by malware.

7- HTTP

Structure:

Requested method (Request) / HTTP version (Response)	space	Requested URL (Request) / Status code (Response)	space	HTTP version (Request) / Status phrase (Response)	Request / Response Line
Header field name	space	value	space		
					Request / Response Header
Header field name	space	value	space		
Blank line					Request / Response Body
Message body					

Requested method: the type of requested needed to be sent to the web server. (GET, POST, DELETE, PUT, HEAD)

HTTP version: the version of http used (ex: HTTP 1.0, HTTP 1.1).

Requested URL: the URL requested by the client.

Status code: 3-digits tells us status of the response (ex: 200, 300, 400).

Status phrase: short description of the status code.

Request Header: tells us information about how data that is wanted from the web server such as the data in plaintext format. Ex:

- Header field: Accept Value: image/jpeg
- Header field: Accept-language Value: en-us
- Header field: user-agent Value: Mozilla/4.0
- Header field: Accept-Encoding Value: {coding type}
- Header field: Accept-Ranges Value: bytes

- **Header field:** Connection **Value:** {Keep-alive/close}

Response Header: additional information related to the response data and the server. Ex:

- **Header field:** Date **Value:** {date and time}
- **Header field:** Server **Value:** {server OS}
- **Header field:** Last-Modified **Value:** {date and time}
- **Header field:** Accept-Ranges **Value:** bytes
- **Header field:** Content-Length **Value:** {length}
- **Header field:** content-type **Value:** text/html

Request body: is an optional part if there is a requirement data from the client such as any input from the them. (search, comment, feedback, etc.)

Response body: includes the requested data by client from the web server.

Normal:

- HTTP uses TCP on port **80** or **8080** or **8088** at the web server.
- HTTP has no encryption and shows the data with plaintext format.
- HTTP shows the fully domain name with specific host. (FQDN: host name + domain name)

Suspicious:

- Using IP address instead of FQDN unless it is internal server.
- Notice if it's encrypted. This is pointer to something try to hide malicious code or web shell.
- Notice web attacks behavior such as SQLI, XSS, Code I, LFI-RFI, IDOR.
- Notice automated tools name such as SQLmap in user-agent strings.
- Notice the number of http request packages into the web server (DOS) or to any input from the client. (Brute force)
- Notice the response payload for malicious files and malwares.
- Notice no of the outbound traffic as it could point to data exfiltration.

- Be aware when notice unusual URL pattern or extensions such as .exe or .zip as could be downloading malware.
- Also if you at organization you must notice the unusual timing for using or browsing through HTTP.

While we are talking about HTTP, we must also mention HTTPS.

It is the secure version of HTTP using the power of **SSL/TLS** encryption methods to encrypt the data transferred between client and server and ensures privacy and authentication.

To understand how it works, we should notice the concepts of SSL/TLS.

8- SSL

structure:

Handshake protocol	Change cipher spec protocol (8 bit)	Alert protocol (16 bit)	HTTP
SSL record protocol			
TCP			
IP			

Handshake protocol: establish the connection between client (client web browser) and web server.

- The client sends a Client Hello message to the server to define its SSL version it can support, session ID and cipher suite which contains cryptography methods the client supports and the same parameters for Server Hello message which is sent from the server to the client.
- The server sends its certificate and encryption key to the client and requests for client authentication.
- The client checks the certificate validation and then it sends its digital certificate to the web server.
- The client uses server **public key** to encrypt its own **private key**, then the client sends the **encrypted private key** to the server which will use this private key to encrypt the data.
- The client sends the cipher functions to the server and ends the handshake from its side.
- Then the web server also sends his cipher algorithms and ends the handshake from its side.
- The data now is sent encrypted using the client **private key**.

Change cipher spec protocol: It is 1 byte has a value of 1, it copies pending state (if the handshake protocol has not completed) to current state to update its cipher suite.

Alert protocol: for reporting error detected from client or server. It consists of 8-bit Level and 8-bit Alert.

- 8-bit level: describes alert level (warning and Fatal).
 - (1:warning)**
 - Bad certificate
 - No certificate
 - Certificate expired
 - Certificate unknown
 - (2:Fatal)**
 - Handshake failure
 - Decompression failure
 - Illegal parameters
 - close notify
 - un supported certificate
 - certificate revoked
 - Bad record MAC
 - unexpected message
- 8-bit Alert: is the alert code number of the above messages

SSL record protocol: responsible for encrypted data transmission and encapsulation of the data sent by the higher layer protocols also to provide basic security services to higher layer protocols such as Confidentiality, integrity and authentication.

9- TLS

Steps:

Client Hello: sent from client to server to establish the connection and to provide its parameters.

Server Hello: sent from server to the client to provide its parameters.

- Record header: contain the content type (Handshake), version of TLS and length.
- Handshake protocol: contains Handshake message type (client / server Hello) and length.
- Client version: TLS version
- Client Random: 32-bit random data
- Session ID: ID of the session between client and server
- Cipher suites: contains a list of which cryptographic methods it will support for key exchange, encryption with that exchanged key.
- Compression methods: contains a list of which compression methods it will support
- Extensions lists: list of optional extensions which the client or server can use to take action or enable new features.

Server Certificate: the server provides its certificate containing the server hostname, public key used by server and a proof from a 3rd party that the owner of this hostname has the private key of this public key.

- Record header: contain the content type (Handshake), version of TLS and length.
- Handshake protocol: contains Handshake message type (certificate) and certificates length.
- Certificates: certificate length and the certificate sent by the server.

Server key exchange generation: The server calculates a private/public keypair for key exchange.

Server key exchange: the server sends its public key to the client.

- Record header: contain the content type (Handshake) and version of TLS and length.
- Handshake protocol: contains Handshake message type (server key exchange) and length.
- Type of encryption: public key and length

Server Hello done: The server indicates it's finished with its half of the handshake.

- Record header: contain the content type (Handshake) and version of TLS and length.
- Handshake protocol: contains Handshake message type (Server Hello done) and length.

Client key exchange generation: The client calculates a private/public keypair for key exchange.

Client key exchange: the client encrypts its private key (premaster secret) using server public key which had been authenticated by the certificate through the client web browser and send it to the server.

- Record header: contain the content type (Handshake) and version of TLS and length.
- Handshake protocol: contains Handshake message type (client key exchange) and length.
- Type of encryption: public key and length

Each side now can calculate encryption keys used by each side based on random number and public key of each side.

Server application data: The server can now decrypt the client private key and use it to encrypt the data.

Client application data: The client sends the data it wants to the server.

Client close notify: client sends an alert that it is closing the connection.

NOTE: SSL/TLS use asymmetric and symmetric encryption.

NOTE: TLS has more than one handshake type based on its version.

10- HTTPS

After we understanding the basic ideas of SSH/TLS we can now identify that HTTPS is same as HTTP with a security special feature.

Normal:

- uses TCP on port 443 or 8443
- Data is encrypted.
- Domain names presents its FQDN as in HTTP.

Suspicious:

- Data is not encrypted.
- No SSL/TLS handshake which is the base of security transmission.
- SSL/TLS header should not be empty.
- Notice if the is any expired certificate or self-signed certificate or certificated issued by untrusted authorities.
- Notice the size of the packet transferred ass it could have a malware payload or suspicious files.
- Be aware of the hostname and make sure that the requested hostname is the same as the one in the certificate.
- User agent behavior such as using automated tools or generated from unexpected geographic locations.
- (Spurious Retransmission) messages which means that the client believe that the server has not received the message, so the client decides to send it back. this pointing to some kind of Ransomware attacks, also you may notice (Zerowindow)
- Notice any suspicious domain name connecting on port 443 as it could be a C&C server.